

VIETNAM NATIONAL UNIVERSITY, HO CHI MINH CITY
UNIVERSITY OF SCIENCE
FACULTY OF INFORMATION TECHNOLOGY



Báo cáo đồ án 2

**Topic: Xây dựng Ứng dụng Web Serverless với Kiến trúc
bảo mật & Tối ưu chi phí**

Course: Nhập môn điện toán đám mây

Prepared by

Nguyễn Minh Tú 23120101

Nguyễn Xuân Duy 23120121

Nguyễn Minh Hiếu 23120124

Ngày 7 tháng 6 năm 2026

Mục lục

I	Giới thiệu	3
1	Phạm vi ứng dụng	3
2	Tóm tắt triển khai	3
3	Thông tin endpoint	4
II	Kiến trúc hệ thống	5
1	Sơ đồ kiến trúc	5
2	Luồng request	6
3	Tự mở rộng serverless	6
4	CDN và Origin Access Control	7
5	VPC Endpoint	7
III	Kết quả và bằng chứng	8
1	Bằng chứng bảo mật frontend	8
2	Bằng chứng Cognito và API security	9
3	Bằng chứng networking	11
4	Bằng chứng IAM	13
5	Giám sát	14
6	Chi phí	16
IV	Chi tiết triển khai	19
1	Source code	19
2	Các triển khai	19
V	Đánh giá	20
1	Bảng đánh giá	20
2	Phân chia công việc	21
A	Phụ lục	22
1	Checklist bằng chứng bắt buộc	22

2	Prompt GenAI	22
3	Ghi chú source code	22

I Giới thiệu

1 Phạm vi ứng dụng

Ứng dụng Task Manager hỗ trợ các chức năng chính sau:

- Đăng ký và đăng nhập người dùng thông qua Amazon Cognito.
- Tạo, xem, cập nhật và xóa công việc.
- Lưu trữ dữ liệu công việc bền vững trong Amazon DynamoDB.
- Chỉ cho phép người dùng đã xác thực gọi các API `/tasks`.

2 Tóm tắt triển khai

Các điểm triển khai chính của hệ thống:

- Frontend được lưu trong S3 bucket riêng tư và chỉ được phục vụ qua CloudFront.
- CloudFront sử dụng Origin Access Control (OAC) để đọc object từ S3.
- Backend sử dụng API Gateway REST API stage `prod` và bốn Lambda function riêng biệt.
- Runtime của Lambda là Node.js 20.x.
- Lambda được đặt trong private subnet của custom VPC `TaskManagerVPC`.
- Lambda truy cập DynamoDB thông qua DynamoDB Gateway VPC Endpoint.
- API được bảo vệ bằng Cognito Authorizer.
- IAM được cấu hình theo nguyên tắc least privilege với bốn role riêng cho bốn Lambda function.
- CloudWatch Dashboard, CloudWatch Alarms, SNS và AWS Budget được cấu hình để giám sát và kiểm soát chi phí.

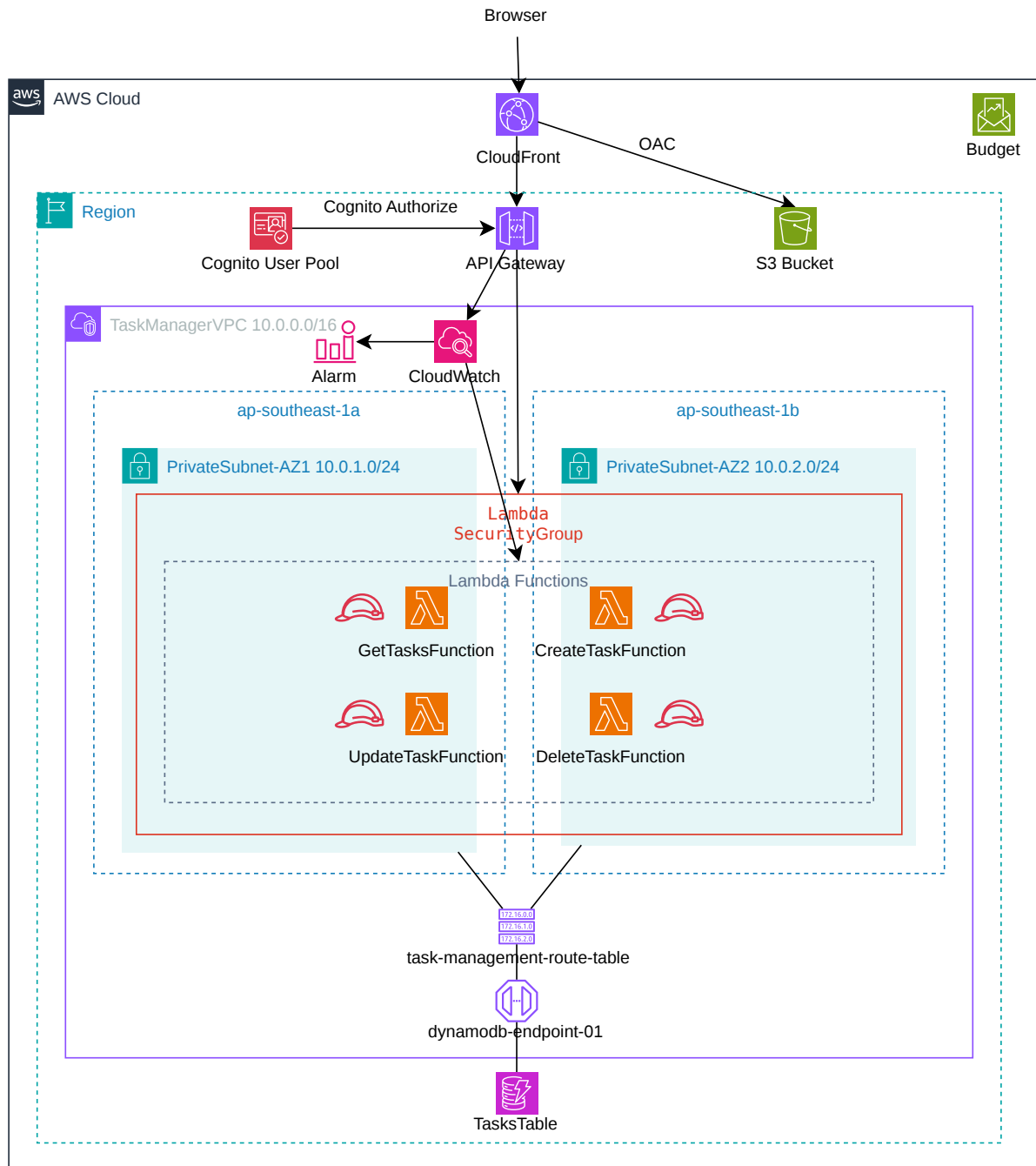
3 Thông tin endpoint

Thông tin	Giá trị
AWS Region	ap-southeast-1
CloudFront URL	https://d1ikfum6io2m2d.cloudfront.net/
API Gateway URL	https://x8hr2ow73f.execute-api.ap-southeast-1.amazonaws.com/prod/
S3 bucket frontend	https://taskmanager-ui-hieunguyen.s3.ap-southeast-1.amazonaws.com/index.html

Bảng 1: Thông tin triển khai thực tế của hệ thống

II Kiến trúc hệ thống

1 Sơ đồ kiến trúc



Hình 1: Sơ đồ kiến trúc serverless của ứng dụng Task Manager

2 Luồng request

Khi người dùng mở ứng dụng, trình duyệt truy cập CloudFront domain. Nếu các file tĩnh như `index.html`, CSS và JavaScript đã có trong cache, CloudFront trả về trực tiếp từ edge location. Nếu cache miss, CloudFront lấy object từ S3 private bucket thông qua OAC. S3 bucket không public nên truy cập trực tiếp đến URL S3 sẽ bị từ chối.

Luồng tạo công việc sau khi người dùng đăng nhập:

1. Người dùng đăng nhập bằng Cognito và nhận Token ID.
2. Frontend gửi request HTTPS đến API Gateway endpoint `/tasks`, kèm header `Authorization`.
3. API Gateway dùng Cognito Authorizer để xác thực JWT token.
4. Nếu token hợp lệ, API Gateway gọi Lambda function tương ứng.
5. Lambda function chạy trong private subnet của `TaskManagerVPC`.
6. Lambda gửi request đến DynamoDB qua route table có destination là DynamoDB prefix list và target là VPC endpoint.
7. DynamoDB ghi hoặc đọc dữ liệu trong `TasksTable`.
8. Lambda trả JSON response về API Gateway, sau đó API Gateway trả kết quả về trình duyệt.

3 Tự mở rộng serverless

Hệ thống không cần Application Load Balancer vì API Gateway đã đóng vai trò entry point HTTPS và định tuyến request đến Lambda. Khi có nhiều request đồng thời, Lambda tự động tạo thêm execution environment để xử lý song song. Khi không có request, Lambda có thể giảm về không instance đang chạy, giúp giảm chi phí vận hành.

Trong phiên bản triển khai hiện tại, nhóm chưa cấu hình reserved concurrency cho các Lambda function. Lý do là hệ thống còn nhỏ, phục vụ mục đích demo và chưa có dữ liệu tải thực tế từ người dùng để xác định ngưỡng concurrency hợp lý. Nếu đặt reserved concurrency dựa trên phỏng đoán, giá trị quá thấp có thể gây throttling không cần thiết, còn giá trị quá cao không tạo thêm lợi ích kiểm soát chi phí so với quy mô hiện tại. Vì vậy, nhóm ưu tiên dùng API Gateway throttling,

CloudWatch monitoring và AWS Budget để kiểm soát lưu lượng, lỗi và chi phí trước. Reserved concurrency sẽ được cấu hình sau khi có baseline về số request, thời gian xử lý và mức concurrency thực tế.

4 CDN và Origin Access Control

CloudFront giúp giảm độ trễ bằng cách cache static assets tại edge location gần người dùng. Khi cache hit, CloudFront trả nội dung mà không cần truy cập lại S3. Khi cache miss, CloudFront lấy nội dung từ origin là S3 bucket.

S3 bucket phải private để người dùng không thể truy cập trực tiếp file bằng URL S3. Nếu S3 public, người dùng có thể bypass CloudFront, làm mất các kiểm soát như HTTPS, caching và policy truy cập qua CDN.

OAC cho phép CloudFront đọc file từ S3 private bucket một cách an toàn. Bucket policy chỉ cho phép CloudFront distribution hợp lệ truy cập object. Vì vậy, người dùng phải đi qua CloudFront để mở frontend, còn truy cập trực tiếp S3 sẽ bị từ chối với **403 Forbidden** hoặc **AccessDenied**.

5 VPC Endpoint

Lambda được gắn VpcConfig vào hai private subnet để backend chạy trong mạng riêng. Vì private subnet không có NAT Gateway, Lambda không thể gọi DynamoDB qua internet công cộng. DynamoDB Gateway Endpoint giải quyết vấn đề này bằng cách thêm route đến DynamoDB prefix list trong route table của private subnet.

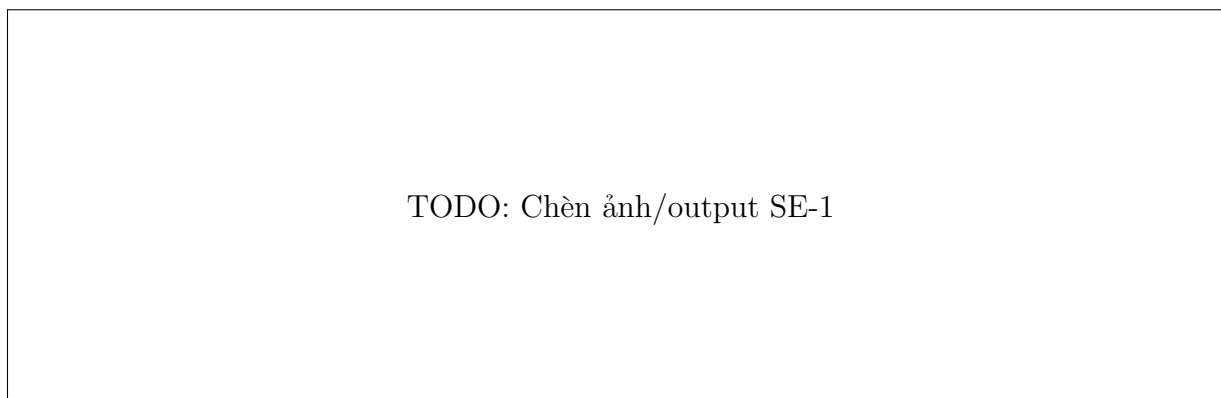
Traffic từ Lambda đến DynamoDB đi qua AWS private backbone theo đường: Lambda trong private subnet → route table → DynamoDB Gateway Endpoint → DynamoDB. Cách này chi phí cố định như NAT Gateway.

III Kết quả và bằng chứng

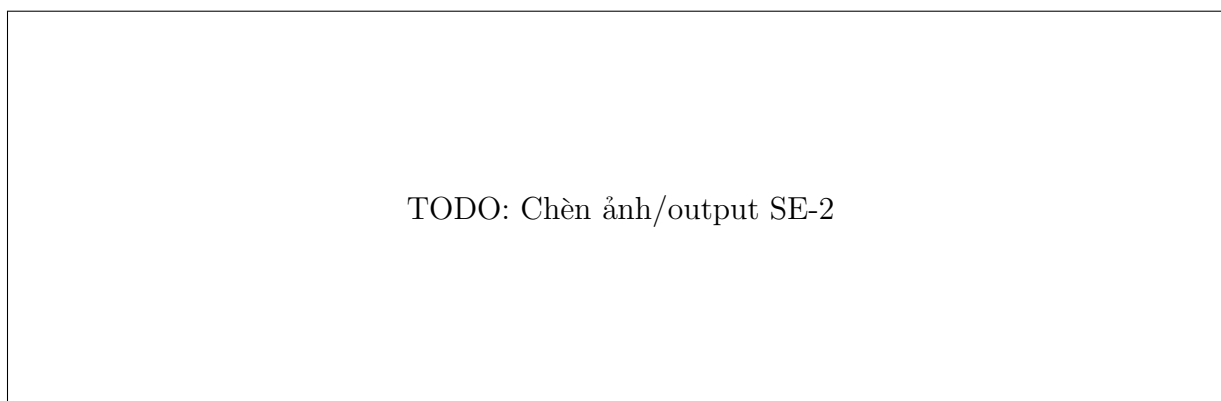
1 Bằng chứng bảo mật frontend

ID	Bằng chứng
SE-1	S3 Block Public Access bật cả bốn tùy chọn.
SE-2	Truy cập trực tiếp S3 URL trả về 403 Forbidden hoặc AccessDenied.
SE-3	Truy cập CloudFront URL thành công với 200 OK.
SE-4	CloudFront distribution có Origin Access Control.

Bảng 2: Bằng chứng bảo mật frontend



Hình 2: Ảnh/output bằng chứng SE-1



Hình 3: Ảnh/output bằng chứng SE-2

TODO: Chèn ảnh/output SE-3

Hình 4: Ảnh/output bằng chứng SE-3

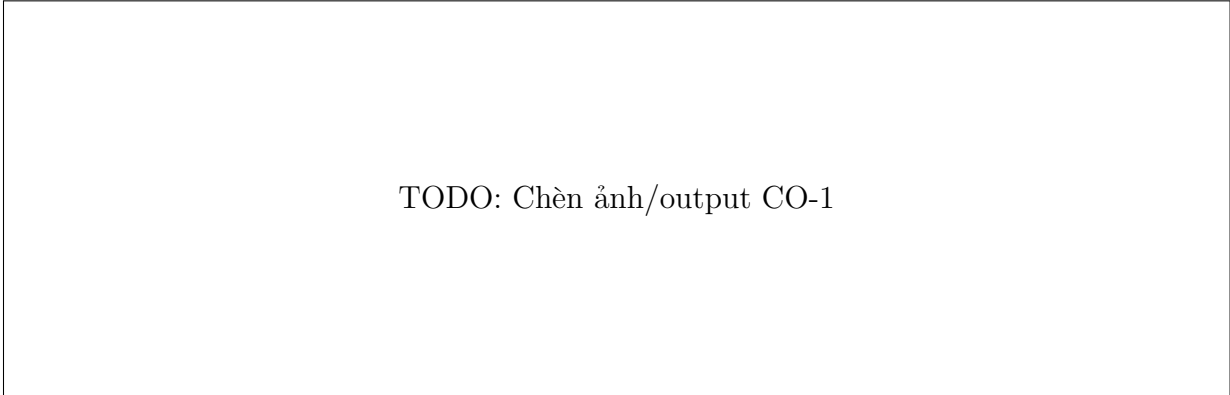
TODO: Chèn ảnh/output SE-4

Hình 5: Ảnh/output bằng chứng SE-4

2 Bằng chứng Cognito và API security

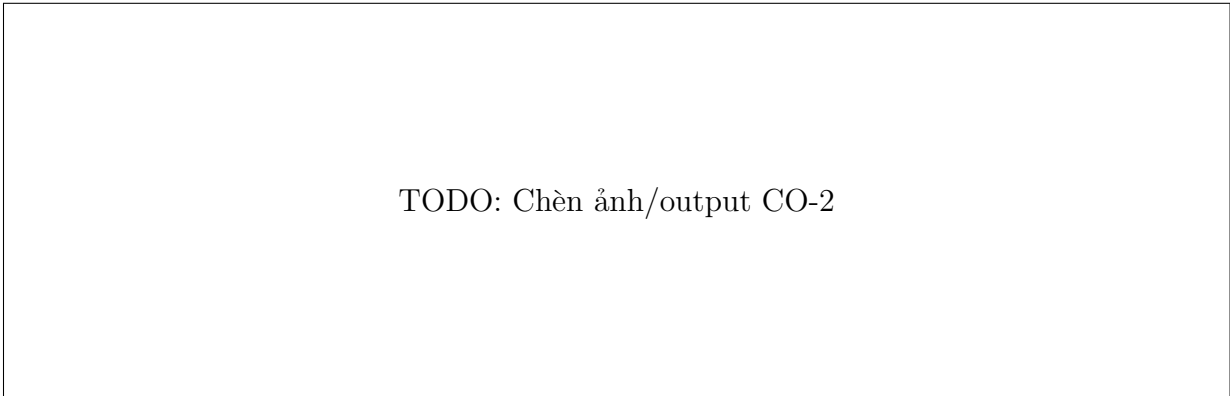
ID	Bằng chứng
CO-1	Cognito User Pool <code>TaskManagerUserPool</code> đã tạo.
CO-2	API Gateway Cognito Authorizer đã cấu hình.
CO-3	Gọi API không có token trả về <code>401 Unauthorized</code> .
CO-4	Gọi API với token hợp lệ trả về <code>200 OK</code> .

Bảng 3: Bằng chứng Cognito và API security



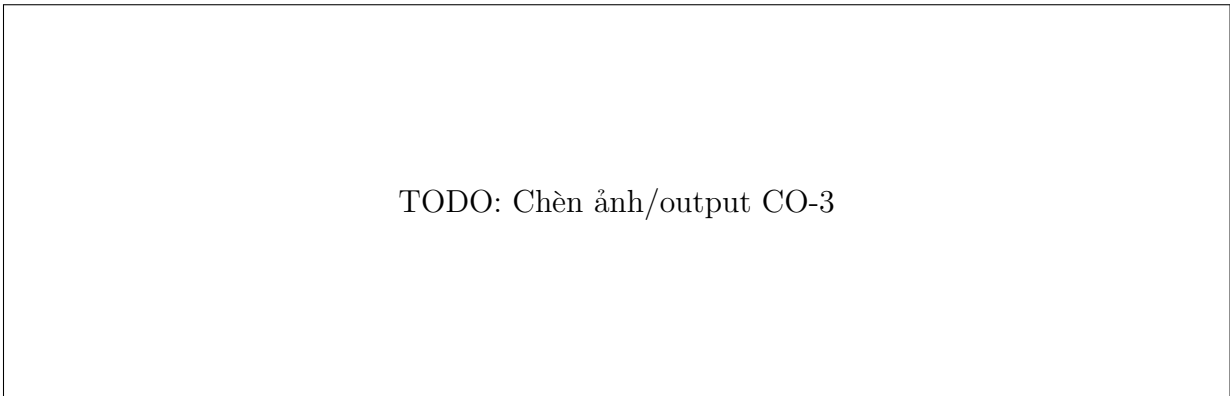
TODO: Chèn ảnh/output CO-1

Hình 6: Ảnh/output bằng chứng CO-1



TODO: Chèn ảnh/output CO-2

Hình 7: Ảnh/output bằng chứng CO-2



TODO: Chèn ảnh/output CO-3

Hình 8: Ảnh/output bằng chứng CO-3

TODO: Chèn ảnh/output CO-4

Hình 9: Ảnh/output bằng chứng CO-4

3 Bằng chứng networking

ID	Bằng chứng
NE-1	DynamoDB Gateway Endpoint có status Available .
NE-2	Lambda có VpcConfig với private subnets và security group.
NE-3	Route table có dòng pl-xxxxxx -> vpce-xxxxxxxx .
NE-4	Không có NAT Gateway đang hoạt động.
NE-5	CloudWatch log cho thấy Lambda gọi DynamoDB thành công.

Bảng 4: Bằng chứng networking

TODO: Chèn ảnh/output NE-1

Hình 10: Ảnh/output bằng chứng NE-1

TODO: Chèn ảnh/output NE-2

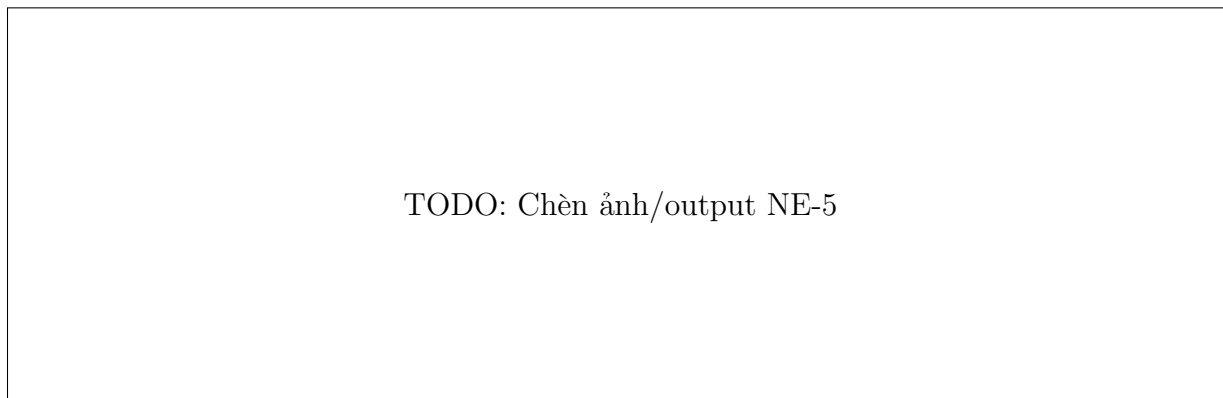
Hình 11: Ảnh/output bằng chứng NE-2

TODO: Chèn ảnh/output NE-3

Hình 12: Ảnh/output bằng chứng NE-3

TODO: Chèn ảnh/output NE-4

Hình 13: Ảnh/output bằng chứng NE-4

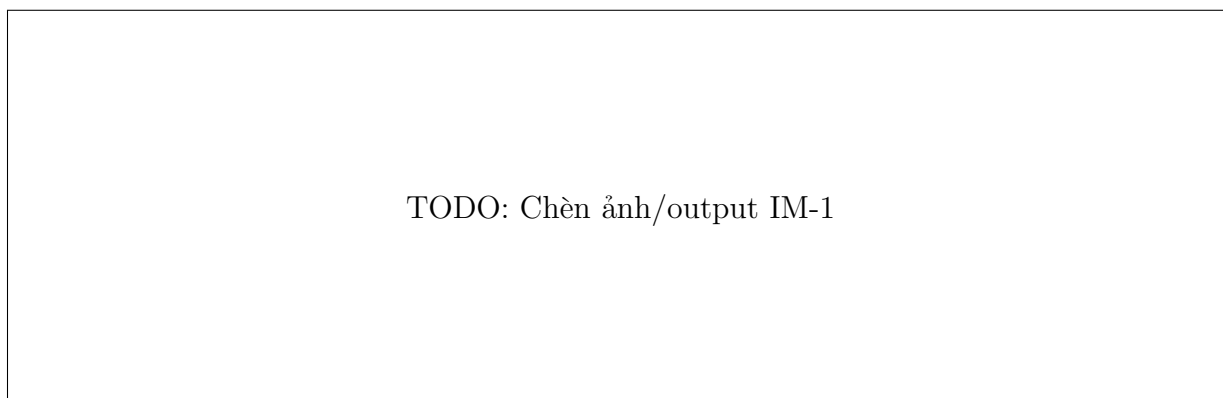


Hình 14: Ảnh/output bằng chứng NE-5

4 Bằng chứng IAM

ID	Bằng chứng
IM-1	Bốn IAM role riêng: <code>GetTasksLambdaRole</code> , <code>CreateTaskLambdaRole</code> , <code>UpdateTaskLambdaRole</code> , <code>DeleteTaskLambdaRole</code> .
IM-2	Policy JSON dùng ARN cụ thể của <code>TasksTable</code> và <code>userId-index</code> , không dùng resource <code>*</code> .
IM-3	Mỗi Lambda function gắn đúng IAM role tương ứng.

Bảng 5: Bằng chứng IAM



Hình 15: Ảnh/output bằng chứng IM-1

TODO: Chèn ảnh/output IM-2

Hình 16: Ảnh/output bằng chứng IM-2

TODO: Chèn ảnh/output IM-3

Hình 17: Ảnh/output bằng chứng IM-3

5 Giám sát

Mục	Yêu cầu
CloudWatch Dashboard	Tối thiểu 5 widget có dữ liệu thực.
Lambda-Error-Alarm	Errors lớn hơn 10 trong 5 phút.
API-5xx-Alarm	5XXError lớn hơn 5 trong 5 phút.
Log request thành công	Có <code>REPORT</code> , status 200, duration, billed duration, memory used.
Log request lỗi	Có lỗi validation hoặc stack trace khi input không hợp lệ.

Bảng 6: Bằng chứng monitoring và logging

TODO: Chèn ảnh/output CloudWatch Dashboard

Hình 18: Ảnh/output CloudWatch Dashboard

TODO: Chèn ảnh/output Lambda Error Alarm

Hình 19: Ảnh/output Lambda Error Alarm

TODO: Chèn ảnh/output API 5xx Alarm

Hình 20: Ảnh/output API 5xx Alarm

TODO: Chèn ảnh/output Log request thành công

Hình 21: Ảnh/output Log request thành công

TODO: Chèn ảnh/output Log request lỗi

Hình 22: Ảnh/output Log request lỗi

6 Chi phí

Mục	Giá trị
Budget name	TaskManager-Budget-0.01
Monthly budget	0.01 USD
Alert 80%	0.008 USD
Alert 100%	0.01 USD
Actual cost	TODO: điền chi phí thực tế từ Billing Dashboard hoặc Cost Explorer

Bảng 7: Bảng chứng kiểm soát chi phí

TODO: Chèn ảnh/output AWS Budget

Hình 23: Ảnh/output AWS Budget

TODO: Chèn ảnh/output Budget monthly limit

Hình 24: Ảnh/output Budget monthly limit

TODO: Chèn ảnh/output Budget alert 80%

Hình 25: Ảnh/output Budget alert 80%

TODO: Chèn ảnh/output Budget alert 100%

Hình 26: Ảnh/output Budget alert 100%

TODO: Chèn ảnh/output Cost Explorer hoặc Billing Dashboard

Hình 27: Ảnh/output Cost Explorer hoặc Billing Dashboard

IV Chi tiết triển khai

1 Source code

2 Các triển khai

V Đánh giá

1 Bảng đánh giá

Hạng mục	Tỷ trọng	Yêu cầu điểm tối đa	Điểm đánh giá
Chức năng	20%	Bốn thao tác CRUD hoạt động đúng. Frontend, backend và DynamoDB tích hợp chính xác. Bộ lọc theo độ ưu tiên và ngày hết hạn hoạt động.	20 / 20
Triển khai Đám mây	25%	S3 private và CloudFront OAC được xác minh. Lambda trong VPC có DynamoDB Endpoint. IAM least privilege với role riêng. Cognito xác thực đúng. CORS chỉ cho phép CloudFront domain.	25 / 25
Hiểu biết Kiến trúc	20%	Giải thích được luồng request, VPC Endpoint, lý do thay thế NAT Gateway, Lambda auto-scaling, API Gateway load balancing, CloudFront caching và OAC.	20 / 20
Giám sát	10%	CloudWatch Dashboard có ít nhất 5 widget với dữ liệu thực. Hai alarm được tạo. Có log request thành công, log request lỗi và SNS email notification.	10 / 10
Hiệu quả Chi phí	15%	Không có NAT Gateway. API Gateway throttling, CloudWatch monitoring và AWS Budget 0.01 USD được cấu hình để kiểm soát chi phí. Reserved concurrency chưa được đặt do chưa có baseline tải thực tế. Tổng chi phí bằng 0 hoặc gần 0.	15 / 15
Tài liệu	10%	Báo cáo giải thích đủ bốn khái niệm chính, sơ đồ kiến trúc đủ thành phần, đủ 16 mục bằng chứng SE/NE/IM/CO, có prompt GenAI nếu sử dụng, và nộp source code.	10 / 10

Bảng 8: Bảng đánh giá theo rubric của đồ án

2 Phân chia công việc

Thành viên	MSSV	Công việc chính	Đóng góp
Nguyễn Minh Tú	23120101	Triển khai bốn Lambda Function cho các thao tác CRUD, cấu hình runtime Node.js 20.x. Thiết lập Cognito User Pool, App Client.	33.3%
Nguyễn Xuân Duy	23120121	Thiết kế và tạo bảng DynamoDB TasksTable , GSI userId-index và dữ liệu demo. Cấu hình IAM Least Privilege cho Lambda roles. Thiết lập CloudWatch Dashboard, CloudWatch Alarms, SNS notification, AWS Budget và các kiểm soát chi phí.	33.3%
Nguyễn Minh Hiếu	23120124	Thiết lập networking gồm custom VPC, private subnets, route table, security group và DynamoDB Gateway Endpoint. Cấu hình API Gateway REST API, Cognito Authorizer, stage prod , CORS. Triển khai S3 private bucket, CloudFront distribution và OAC cho frontend.	33.3%

Bảng 9: Bảng phân chia công việc nhóm

A Phụ lục

1 Checklist bằng chứng bắt buộc

ID	Bằng chứng	Đã có
SE-1	S3 Block Public Access bật cả bốn tùy chọn.	TODO
SE-2	Direct S3 access trả về 403 Forbidden.	TODO
SE-3	CloudFront access trả về 200 OK.	TODO
SE-4	OAC gắn vào CloudFront distribution.	TODO
CO-1	Cognito User Pool đã tạo.	TODO
CO-2	API Gateway Cognito Authorizer được cấu hình.	TODO
CO-3	API không có token trả về 401 Unauthorized.	TODO
CO-4	API có token hợp lệ trả về 200 OK.	TODO
NE-1	DynamoDB VPC Endpoint status Available.	TODO
NE-2	Lambda VpcConfig có private subnets và security group.	TODO
NE-3	Route table có route pl-xxxxxx -> vpce-xxxxxxx.	TODO
NE-4	Không có NAT Gateway đang hoạt động.	TODO
NE-5	CloudWatch log cho thấy Lambda gọi DynamoDB thành công.	TODO
IM-1	Bốn IAM role riêng cho bốn Lambda function.	TODO
IM-2	IAM policy dùng ARN cụ thể của DynamoDB table/index, không dùng resource *.	TODO
IM-3	Mỗi Lambda function gắn đúng role tương ứng.	TODO

Bảng 10: Checklist bằng chứng SE/CO/NE/IM

2 Prompt GenAI

Vì nhóm có sử dụng GenAI để hỗ trợ lập dàn ý và viết báo cáo, cần nộp kèm lịch sử prompt hoặc screenshot đoạn hội thoại theo yêu cầu đề án.

- TODO: Chèn hoặc đính kèm lịch sử prompt đã sử dụng.
- TODO: Chèn screenshot hội thoại nếu nộp dưới dạng hình ảnh.

3 Ghi chú source code

Source code cần nộp kèm gồm:

- Frontend: HTML, CSS, JavaScript.
- Backend: mã Node.js 20.x cho bốn Lambda handler.
- README mô tả cách chạy local và cách deploy lên AWS.

Không có source code IaC vì hạ tầng được triển khai thủ công bằng AWS Console.